Reporte técnico de vulnerabilidad

Curso **Software Seguro** · Módulo V — Laboratorios prácticos · Documento confidencial (uso autorizado)

ID del hallazgo	VULN-0005
Título	Enumeración de códigos válidos mediante canal lateral de temporización (divulgación de información)
Laboratorio / activo	Asistencia — entorno de práctica autorizado del curso
URL / endpoint	`POST https://chl-<id>-asistencia.softwareseguro.com.ar/index.php`
Severidad	**MEDIA — CVSS v3.1: 5.3**
Clasificación	CWE-208 / CWE-203 / CWE-200 · OWASP A05:2021 Security Misconfiguration
Fecha de detección	2026-11-11
Autor/a	Sofía Lourdes Toledo Criado
Estado	Resuelto en laboratorio · remediación recomendada

1. Identificación y trazabilidad

Campo	Valor
ID del hallazgo	VULN-0005
Aplicación / activo	Formulario "Verificar Código" del laboratorio Asistencia (PHP 8.0.30 tras Cloudflare)
URL / endpoint	`POST /index.php` (cuerpo `codigo`, `clave`)
Fecha de detección	2026-11-11
Reportado por	Sofía Lourdes Toledo Criado
Estado	Resuelto en laboratorio; remediación pendiente del lado del servidor
Alcance autorizado	Challenge del curso, clave de prueba inválida, sin acceso a datos reales de terceros

2. Resumen ejecutivo

Hallazgo: el formulario de verificación responde siempre el mismo mensaje ("No se puede acceder a esta información") ante una clave incorrecta, pero **tarda mucho más** cuando el código corresponde a un asistente real. Esa diferencia de tiempo permite distinguir los códigos válidos de los inexistentes **sin conocer la clave** y, contándolos, deducir la cantidad total de asistentes.

Riesgo para el negocio: un atacante no autenticado puede enumerar qué identificadores existen y obtener un dato agregado protegido (cantidad de asistentes), además de preparar ataques dirigidos posteriores (p. ej. fuerza bruta de clave solo sobre códigos reales).

Impacto principal sobre la tríada CIA: Confidencialidad. No se afectan integridad ni disponibilidad.

Severidad y prioridad: Media (CVSS v3.1 5.3). Prioridad de corrección media: la falla es fácil de explotar de forma remota y silenciosa, aunque la información expuesta en este laboratorio es acotada.

Acción recomendada: uniformar el tiempo de respuesta entre códigos válidos e inexistentes (ejecutar siempre una verificación de clave aunque el código no exista) y aplicar rate limiting.

3. Detalles técnicos

3.1 Descripción

El endpoint `POST /index.php` recibe `codigo` (3 dígitos) y `clave`. Ante una clave incorrecta devuelve un HTML idéntico para todos los códigos, por lo que **el contenido de la respuesta no distingue** códigos válidos de inexistentes. Sin embargo, el servidor solo ejecuta la verificación costosa de la clave (hash/consulta) cuando el código **sí existe**, lo que introduce una demora observable (~1 s) frente a los ~95 ms de un código inexistente. Esta discrepancia temporal es un canal lateral que permite enumerar los códigos válidos.

3.2 Componentes afectados

- **Aplicación / versión:** Asistencia, backend PHP/8.0.30, detrás de Cloudflare.
- **Método y ruta HTTP:** `POST /index.php`.
- **Parámetros involucrados:** `codigo`, `clave`.
- **Roles o permisos necesarios:** ninguno (acceso anónimo; no se requiere la clave).
- **Entorno y fecha de prueba:** laboratorio autorizado, 2026-11-11.

3.3 Clasificación y causa raíz

- **CWE:** CWE-208 (Observable Timing Discrepancy); relacionadas CWE-203 (Observable Discrepancy) y CWE-200 (Exposure of Sensitive Information).
- **CVE:** No aplica (debilidad de configuración/implementación propia del laboratorio).
- **Referencia OWASP:** A05:2021 — Security Misconfiguration (comportamiento observable que filtra información).
- **Causa raíz probable:** la lógica de verificación hace trabajo distinto según exista o no el código (short-circuit para inexistentes), sin normalizar el tiempo de respuesta.

3.4 Impacto técnico y alcance

Bajo las condiciones verificadas, un atacante remoto y anónimo puede: (1) determinar qué códigos de 3 dígitos corresponden a asistentes reales midiendo el tiempo de respuesta, y (2) contar esos códigos para obtener la cantidad total de asistentes. No se demostró acceso a datos personales ni modificación o borrado de información; el impacto comprobado es de **divulgación de información**.

4. Métricas CVSS

Versión utilizada: CVSS v3.1.

Métrica	Valor / justificación
Vector CVSS completo	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`
Puntaje base	**5.3**
Severidad CVSS	**Media** (4.0–6.9)
Calculadora / fuente	FIRST — `first.org/cvss/calculator/3.1`
Prioridad interna	Media: explotación remota y silenciosa, pero información expuesta acotada en este entorno.

Métrica base	Valor	Justificación
AV — Vector de ataque	N (Red)	Se explota vía HTTP sobre Internet.
AC — Complejidad	L (Baja)	La separación de tiempos (~95 ms vs ~1 s) es neta y reproducible; basta repetir muestras.
PR — Privilegios	N (Ninguno)	No se requiere la clave ni sesión.
UI — Interacción	N (Ninguna)	No requiere acción de una víctima.
S — Alcance	U (Sin cambios)	Impacto dentro del mismo componente.
C — Confidencialidad	L (Baja)	Se filtra la existencia de códigos y la cantidad de asistentes; no datos personales masivos.
I — Integridad	N (Ninguna)	No se altera información.

A — Disponibilidad	N (Ninguna)	No se afecta el servicio.

Justificación: el puntaje 5.3 refleja una divulgación de información remota, sin privilegios ni interacción, con impacto limitado a la confidencialidad. Si los códigos válidos habilitaran el acceso a datos sensibles del titular, la métrica C debería reevaluarse al alza.

5. Prueba de concepto (PoC) — paso a paso

Objetivo: demostrar que el tiempo de respuesta revela los códigos válidos y permite contar los asistentes sin la clave.

Precondiciones: entorno de laboratorio autorizado; clave de prueba inválida; cookie de sesión propia (no se incluye en el reporte).

Herramientas: navegador + DevTools, Burp Suite (Intruder/Repeater), script propio en Python (medición secuencial de tiempos).

1. **Preparación:** capturar en DevTools → Network la petición real `POST /index.php` con `codigo` y `clave`; descartar el ruido de Cloudflare (`/cdn-cgi/rum`).
2. **Solicitud inicial:** enviar `codigo=123&clave=xxxx` y registrar la respuesta base.
3. **Observación del contenido:** comprobar que el HTML es idéntico para distintos códigos (el cuerpo no discrimina).
4. **Modificación controlada:** variar solo `codigo` en el rango completo `000` – `999`, con clave fija inválida.
5. **Ejecución:** medir el tiempo de respuesta de cada código (Intruder o script secuencial — no concurrente, para no corromper la medición).
6. **Verificación:** clasificar por tiempo (≈95 ms = inexistente; ≈1 s = asistente válido) y re-medir los candidatos para descartar jitter de red.
7. **Cierre:** contar los códigos válidos confirmados; ese total es la cantidad de asistentes. No se alteró ni persistió ningún dato.

5.1 Evidencia

Solicitud HTTP sanitizada:

```
POST /index.php HTTP/2
Host: chl-<id>-asistencia.softwareseguro.com.ar
Content-Type: application/x-www-form-urlencoded
Cookie: cf_clearance=[REDACTADO]

codigo=123&clave=xxxx
```

Respuesta (idéntica para códigos válidos e inexistentes ante clave incorrecta):

```
HTTP/2 200 OK
Content-Type: text/html; charset=UTF-8
x-powered-by: PHP/8.0.30

... <div class="note" style="color: red; font-size: 20px">
    No se puede acceder a esta información
</div> ...
```

Señal diferencial — muestra de tiempos de respuesta (columna "Response received"):

codigo	Tiempo (mediana)	Clasificación
101, 110, 200, 999 (ejemplos)	~95 ms	Inexistente (corte inmediato)
100	~1206 ms	Asistente válido
205	~1062 ms	Asistente válido
447	~1078 ms	Asistente válido
683	~1233 ms	Asistente válido
997	~1124 ms	Asistente válido

> **Hallazgo clave:** los códigos válidos **no son secuenciales**; están dispersos en todo el rango `000` – `999` (p. ej. `205`, `447`, `683`, `997`). El

> dato "no superan los 200" acota la **cantidad**, no el **rango**: un barrido limitado a `000` – `199` habría sido incorrecto.

Validación del resultado:

Verificación	Resultado
Coincidencia Burp ↔ script en `000` – `199`	Los mismos 20 códigos en ambas herramientas
Falsos positivos por jitter (064, 097, 136, 186)	Descartados: no repiten la demora al re-medir
Separación de poblaciones	Bimodal limpia: ~95 ms vs ~1 s, sin valores intermedios
Re-test en Repeater (válidos vs inexistentes)	Confirmado
Control de coherencia con la cota del enunciado	159 ≤ 200

Resultado esperado (sistema seguro): el tiempo de respuesta sería constante para cualquier código, impidiendo distinguir válidos de inexistentes.

Resultado observado: los códigos válidos tardan ~1 s de forma consistente.

Conclusión de la PoC: se enumeraron **159 códigos válidos** → **159 asistentes**. Código ganador del laboratorio: `md5("159") = 140f6969d5213fd0ece03148e62e461e` (aceptado por la plataforma).

6. Recomendaciones de remediación

6.1 Corrección inmediata

Normalizar el tiempo de respuesta: ejecutar siempre la verificación de clave (contra un hash *dummy* cuando el código no exista), de modo que válidos e inexistentes tarden lo mismo. Devolver el mismo mensaje y estado en todos los casos de error.

6.2 Medidas complementarias

- Aplicar **rate limiting** y detección de enumeración (200–1000 peticiones secuenciales es un patrón detectable).
- Requerir autenticación/autorización antes de evaluar la existencia del código.
- Usar identificadores **no secuenciales ni cortos** (p. ej. UUID) cuando no deban ser adivinables.
- Revisar que el framework no introduzca otras discrepancias observables (cabeceras, tamaños, tiempos).

6.3 Criterios de aceptación

- ☐ El tiempo de respuesta es indistinguible entre código válido e inexistente.
- ☐ Todos los errores devuelven el mismo mensaje y estado.
- ☐ El rate limiting bloquea la enumeración masiva.
- ☐ Se ejecutaron pruebas de regresión (timing + contenido).

Responsable sugerido: equipo de desarrollo backend. **Fecha objetivo:** a definir según prioridad.

7. Validación posterior y seguimiento

Fecha	Responsable	Acción	Resultado
2026-11-11	S. Toledo Criado	Enumeración por timing + conteo	Hallazgo confirmado (159 asistentes)
[A definir]	Backend	Retest tras normalizar tiempos	Pendiente

Estado final: Abierto (resuelto como challenge; remediación del lado servidor pendiente).

8. Referencias

- OWASP Top 10 — A05:2021 Security Misconfiguration: https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- MITRE CWE-208 — Observable Timing Discrepancy: https://cwe.mitre.org/data/definitions/208.html
- MITRE CWE-203 — Observable Discrepancy: https://cwe.mitre.org/data/definitions/203.html

- MITRE CWE-200 — Exposure of Sensitive Information: https://cwe.mitre.org/data/definitions/200.html
- FIRST — CVSS v3.1 Calculator: https://www.first.org/cvss/calculator/3.1

Documento confidencial — uso autorizado del curso Software Seguro. Generado con la plantilla oficial de reportes (Módulo IV). Las pruebas se ejecutaron únicamente sobre el entorno de laboratorio autorizado; los datos sensibles (cookies de sesión) fueron redactados.